

PrimeHealth Clinic & Diagnostic

Information Security Objectives & Plans

Document Version History

Date	Version	Updated By	Details of Change	Approved By
22/10/2024	1.0	Whole Team	Basic Draft of document	Executive Team
24/10/2024	1.0	Whole Team	Draft in progress	Executive Team
26/10/2024	1.0	Whole Team	Document Complete	Executive Team
27/10/2024	1.0	Whole Team Aaron (CEO)	Approval	Executive Team

Table of Content

1.	Purpose.....	2
2.	Scope.....	3
3.	Information Security Objectives	3
4.	Information Security Strategic Plans.....	3
5.	Key Roles and Responsibilities	4
6.	Monitoring and Review	5
7.	Supporting Documentation and References.....	5

1. Purpose

This document outlines the strategic information security objectives and the comprehensive plan for securing sensitive information assets at PrimeHealth Clinic & Diagnostics. Our goal is to ensure that information security aligns seamlessly with PrimeHealth's commitment to excellence in patient care and diagnostics, while adhering to the highest industry standards, including ISO 27001:2022. These objectives will not only protect the organization but also empower us to adapt to new threats and continuously improve our information security posture.

2. Scope

This document applies to PrimeHealth's business processes and information assets that impact the organization's information security.

3. Information Security Objectives

- a. Our information security objectives are designed not only to mitigate risks but also to enhance patient trust, operational resilience, and compliance. PrimeHealth's security strategy is built on the following foundational objectives:
- b. Confidentiality of Patient Data: Ensure that sensitive patient records and health information are protected from unauthorized access and disclosure through comprehensive access controls, encryption protocols, and user authentication processes.
- c. Operational Integrity: Maintain the accuracy, completeness, and trustworthiness of critical data in clinical, diagnostic, and administrative operations, preventing unauthorized modifications or corruptions that could affect care quality or decision-making.
- d. Systems Availability: Guarantee the continuous availability of vital systems and platforms used in diagnostics, telehealth, and patient management, ensuring minimal disruption to services during operational hours.
- e. Regulatory Compliance Excellence: Maintain ongoing compliance with local and international data protection regulations, including HIPAA, GDPR, and ISO 27001. Regular audits will be conducted to ensure we not only meet but exceed regulatory expectations.
- f. Human-Centric Security Awareness: Foster a culture of security awareness across the organization. Regular security training and simulation exercises will be implemented to enhance employee vigilance and prepare the team for potential phishing, ransomware, or social engineering threats.
- g. Swift Incident Response: Establish a well-structured, responsive incident management strategy that allows PrimeHealth to detect, report, and address security breaches swiftly, minimizing impact on operations and patient care.

- h. Proactive Business Continuity and Disaster Preparedness: Implement robust business continuity and disaster recovery plans. These will ensure PrimeHealth can recover from unforeseen incidents, such as natural disasters or cyberattacks, quickly, while preserving the integrity of critical information and restoring services promptly

4. Information Security Strategic Plans

To achieve these objectives, PrimeHealth Clinic & Diagnostics has developed the following strategic plans for the ongoing enhancement and management of our information security program:

- a. Strengthening Our ISMS: Continuously develop and refine the Information Security Management System (ISMS), ensuring it reflects current threats and changes in PrimeHealth's operational environment. The ISMS will guide all risk management efforts, ensuring alignment with ISO 27001 and the organization's overall business goals.
- b. Risk-Based Management Approach: Implement a dynamic risk management framework that emphasizes identifying, evaluating, and mitigating risks that could negatively impact PrimeHealth's ability to deliver high-quality healthcare services. Each risk will be cataloged in the Risk Register, reviewed periodically, and treated based on priority.
- c. Advanced Access and Identity Management: Deploy and maintain role-based access control (RBAC) and multi-factor authentication (MFA) for critical systems, ensuring that only authorized personnel have access to patient data, diagnostic tools, and financial information.
- d. Strategic Incident Response Planning: Regularly test and refine the Incident Response Plan (IRP) to ensure rapid containment, mitigation, and recovery in the event of a security breach or system compromise. PrimeHealth will use incident learnings to continuously evolve the IRP.
- e. Data Segmentation and Encryption: Implement advanced encryption techniques for data at rest and in transit. This will ensure that patient data remains secure, even in the event of unauthorized access. Data segmentation will be applied to isolate sensitive data from less critical information, minimizing risk exposure.
- f. Continuous Monitoring and Threat Intelligence: Establish real-time monitoring of all key systems, coupled with proactive threat intelligence to stay ahead of potential security incidents. These systems will be monitored by the security team 24/7 to detect anomalies or suspicious activities.
- g. Regulatory and Internal Audits: Conduct regular internal audits to assess compliance with HIPAA, GDPR, and other relevant regulations. ISO 27001:2022 audits will be carried out annually to ensure our ISMS remains compliant and effective.

5. Key Roles and Responsibilities

Chief Security Officer (CSO):

- Leads the development and continuous improvement of the ISMS.
- Oversees the implementation of security controls and ensures alignment with regulatory requirements.
- Coordinates incident response, ensuring all breaches are addressed in a timely and effective manner.
- Reports on security risks and treatments to senior management regularly.

Information Security Committee (ISC):

- Reviews the security strategy and approves major decisions regarding risk treatments.
- Ensures the security objectives align with PrimeHealth's broader organizational goals.
- Reviews audits, incidents, and compliance efforts quarterly.

Risk Owners:

- Responsible for managing risks within their respective departments.
- Ensure that identified risks are addressed through appropriate controls and regularly report on residual risks.

IT Department:

- Responsible for the technical implementation of all security measures, including encryption, access control, and monitoring.
- Manages data backups and ensures systems are operational and protected against potential breaches.

Employees and Contractors:

- Participate in mandatory security awareness training.
- Follow organizational policies on data handling and access controls.
- Report any unusual or suspicious activities to the security team immediately.

Third-Party Vendors:

- Adhere to the security requirements outlined in vendor contracts and agreements.
- Provide security compliance documentation regularly and participate in security reviews.

6. Monitoring and Review

The effectiveness of these objectives and plans will be continually monitored through a structured review process, including:

- Quarterly ISC Meetings: To review the status of risk treatments, incidents, and audit findings.

- Annual ISO 27001 Audits: To assess the effectiveness of the ISMS and compliance with ISO 27001:2022.
- Regular Incident Simulations: To test the organization's preparedness for security events and ensure response plans are robust.

7. Supporting Documentation and References

- List of Standards, Frameworks and Legislation
- [ISO27K1-4.3] ISMS Scope Statement
- [ISO27K1_A17.1.1_DC] BCP Documentation
- [ISO27K1_A17.1.1_DC] DRP Documentation
- TRA sheet under [ISO27K1_8.2] Business Processes, Information Assets & Risks Register